

# Contents

|                                                                  |          |
|------------------------------------------------------------------|----------|
| <b>Vol 04: E-Commerce, Social Engineering, Cyber Law</b>         | <b>2</b> |
| <b>L28: E-Commerce Security &amp; TLS/SSL Configuration</b>      | <b>2</b> |
| Purpose . . . . .                                                | 2        |
| OpenSSL — usage steps . . . . .                                  | 2        |
| TLS best practices . . . . .                                     | 2        |
| Countermeasures . . . . .                                        | 2        |
| <b>L29: Payment Security, PCI-DSS &amp; Web Hardening</b>        | <b>3</b> |
| Purpose . . . . .                                                | 3        |
| PCI-DSS key requirements . . . . .                               | 3        |
| ZAP for e-commerce . . . . .                                     | 3        |
| Countermeasures . . . . .                                        | 3        |
| <b>L30: Social Engineering Toolkit &amp; Phishing Simulation</b> | <b>3</b> |
| Purpose . . . . .                                                | 3        |
| SET — usage steps . . . . .                                      | 4        |
| Gophish (alternative) . . . . .                                  | 4        |
| Countermeasures . . . . .                                        | 4        |
| <b>L31: OSINT &amp; Human-Factor Countermeasures</b>             | <b>4</b> |
| Purpose . . . . .                                                | 4        |
| theHarvester — usage steps . . . . .                             | 4        |
| Other OSINT sources . . . . .                                    | 4        |
| Countermeasures . . . . .                                        | 4        |
| <b>L32: Password Attacks with John the Ripper</b>                | <b>5</b> |
| Purpose . . . . .                                                | 5        |
| Usage steps . . . . .                                            | 5        |
| Hash extraction (awareness) . . . . .                            | 5        |
| Countermeasures . . . . .                                        | 5        |
| <b>L33: Network Login Attacks with Hydra &amp; Defense</b>       | <b>5</b> |
| Purpose . . . . .                                                | 5        |
| Usage steps . . . . .                                            | 6        |
| fail2ban defense . . . . .                                       | 6        |
| Countermeasures . . . . .                                        | 6        |
| <b>L34: IT Act 2000 &amp; Indian Cyber Law Essentials</b>        | <b>6</b> |
| Purpose . . . . .                                                | 6        |
| Key IT Act sections . . . . .                                    | 6        |
| DPDP Act 2023 . . . . .                                          | 7        |
| Countermeasures (organizational) . . . . .                       | 7        |
| <b>L35: Digital Evidence, Incident Reporting &amp; CERT-In</b>   | <b>7</b> |
| Purpose . . . . .                                                | 7        |
| Chain of custody . . . . .                                       | 7        |

|                                                                        |          |
|------------------------------------------------------------------------|----------|
| CERT-In reporting (2022 directions) . . . . .                          | 7        |
| Countermeasures . . . . .                                              | 7        |
| <b>L36: Course Synthesis — Tool Chain Integration &amp; Assessment</b> | <b>8</b> |
| Purpose . . . . .                                                      | 8        |
| Capstone scenario . . . . .                                            | 8        |
| Report template . . . . .                                              | 8        |
| Assessment prep . . . . .                                              | 8        |

## Vol 04: E-Commerce, Social Engineering, Cyber Law

**Course:** nou26\_ge86 | **Lectures:** L28–L36

**Instructor:** Prof. Dr. Nilesh K. Modi | IGNOU/BAOU

---

### L28: E-Commerce Security & TLS/SSL Configuration

#### Purpose

E-commerce depends on transport encryption and secure certificate management — PGDCS-103 Block 2, Unit 3.

#### OpenSSL — usage steps

```
# Check certificate
echo | openssl s_client -connect shop.example.com:443 2>/dev/null | openssl x509 -noout -dates

# Test TLS configuration
testssl.sh https://shop.example.com

# Generate self-signed (lab)
openssl req -x509 -newkey rsa:4096 -keyout key.pem -out cert.pem -days 365 -nodes
```

#### TLS best practices

- TLS 1.2 minimum; prefer TLS 1.3.
- Strong cipher suites (AEAD: AES-GCM, ChaCha20).
- HSTS header: `Strict-Transport-Security: max-age=31536000`.
- Certificate transparency monitoring.

#### Countermeasures

- Auto-renew certs (Let's Encrypt, cert-manager).
  - Disable SSLv3, TLS 1.0/1.1.
  - Implement OCSP stapling.
  - Monitor for cert expiry (30-day alerts).
-

*Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.*

## L29: Payment Security, PCI-DSS & Web Hardening

### Purpose

PCI-DSS mandates controls for organizations handling cardholder data.

### PCI-DSS key requirements

1. Install and maintain firewall.
2. No default passwords.
3. Protect stored cardholder data.
4. Encrypt transmission.
5. Use and update antivirus.
6. Develop secure systems.
7. Restrict data access.
8. Unique IDs for each person.
9. Restrict physical access.
10. Track and monitor network access.
11. Regularly test security.
12. Maintain information security policy.

### ZAP for e-commerce

```
# Scan checkout flow
zap-cli quick-scan --self-contained http://shop.lab/checkout
# Check for: mixed content, missing headers, injection in payment fields
```

### Countermeasures

- Tokenize card data (use payment gateway — never store PAN).
- SAQ (Self-Assessment Questionnaire) compliance.
- Quarterly ASV scans (OpenVAS qualified).
- Segregate CDE (Cardholder Data Environment).

---

*Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.*

## L30: Social Engineering Toolkit & Phishing Simulation

### Purpose

Social engineering exploits human psychology — PGDCS-103 Block 2, Unit 4. SET automates phishing and payload delivery in labs.

## SET — usage steps

```
sudo setoolkit
# Menu: 1) Social-Engineering Attacks
#       2) Website Attack Vectors
#       3) Credential Harvester Attack Method
#       2) Site Cloner - clone login page
```

## Gophish (alternative)

1. Install Gophish.
2. Create email template + landing page.
3. Import target group.
4. Launch campaign; track click/submit rates.
5. Use results for awareness training.

## Countermeasures

- Security awareness training (quarterly).
- Phishing reporting button.
- DMARC/DKIM/SPF for email authentication.
- MFA on all external-facing logins.
- Never punish users who report — encourage reporting.

---

*Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.*

## L31: OSINT & Human-Factor Countermeasures

### Purpose

Open-Source Intelligence gathering demonstrates information leakage before technical attacks.

### theHarvester — usage steps

```
theHarvester -d example.com -b google,bing,linkedin
# Collects: emails, subdomains, hosts
```

### Other OSINT sources

- Shodan, Censys — exposed services
- WHOIS / DNS records
- Social media profiles
- Paste sites (breach data)

## Countermeasures

- Minimize public footprint (OPSEC).
- Separate personal and corporate social media.
- Data classification and handling procedures.

- Red-team OSINT exercises to find leaks.
- Privacy settings on all platforms.

---

*Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.*

## L32: Password Attacks with John the Ripper

### Purpose

John the Ripper (JtR) cracks password hashes offline — demonstrates why strong hashing matters.

### Usage steps

```
# Identify hash format
john --list=formats --format=crypt

# Crack /etc/shadow entries (lab)
unshadow /etc/passwd /etc/shadow > combined.txt
john combined.txt
john --wordlist=/usr/share/wordlists/rockyou.txt combined.txt

# Show cracked passwords
john --show combined.txt

# Specific format
john --format=md5crypt combined.txt
```

### Hash extraction (awareness)

```
# From Windows SAM (lab)
# mimikatz or samdump2 - authorized forensics only
```

### Countermeasures

- Store passwords with **bcrypt**, **scrypt**, or **Argon2** — never MD5/SHA1.
- Enforce password complexity + length ( 12 chars).
- Implement account lockout / rate limiting.
- Deploy MFA everywhere.
- Use password managers.

---

*Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.*

## L33: Network Login Attacks with Hydra & Defense

### Purpose

THC-Hydra performs parallelized login brute-forcing against network services.

## Usage steps

```
# SSH brute-force (lab)
hydra -l root -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.101

# HTTP POST form
hydra -l admin -P passwords.txt 192.168.56.101 http-post-form \
  "/login.php:user=~USER~&pass=~PASS~:F=incorrect"

# FTP
hydra -L users.txt -P passwords.txt ftp://192.168.56.101

# Limit threads (avoid DoS)
hydra -t 4 -w 30 ...
```

## fail2ban defense

```
# /etc/fail2ban/jail.local
[sshd]
enabled = true
maxretry = 3
bantime = 3600
```

## Countermeasures

- Disable password auth for SSH; use key-based auth.
- CAPTCHA after N failed logins.
- fail2ban / CrowdStrike / WAF rate limiting.
- Monitor authentication logs (auth.log, Event 4625).

---

*Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.*

## L34: IT Act 2000 & Indian Cyber Law Essentials

### Purpose

Legal framework governing cybercrime in India — Nina Godbole, *Cyber Security*, legal perspectives chapter.

### Key IT Act sections

| Section | Offence                                          |
|---------|--------------------------------------------------|
| 43      | Unauthorized access, damage (civil compensation) |
| 66      | Computer-related offences (criminal)             |
| 66C     | Identity theft                                   |
| 66D     | Cheating by personation (phishing)               |
| 66E     | Violation of privacy (image capture)             |

| Section | Offence                     |
|---------|-----------------------------|
| 66F     | Cyber terrorism             |
| 67      | Publishing obscene material |
| 69      | Govt. interception powers   |
| 72      | Breach of confidentiality   |

## DPDP Act 2023

Personal data processing obligations; consent; data principal rights; penalties up to 250 crore.

### Countermeasures (organizational)

- Maintain lawful interception policies.
- Data Processing Agreements with vendors.
- Incident response aligned with CERT-In reporting.
- Legal review before pentesting contracts.

---

*Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.*

## L35: Digital Evidence, Incident Reporting & CERT-In

### Purpose

Proper evidence handling and timely reporting are legal and operational requirements.

### Chain of custody

1. Identify and isolate affected systems.
2. Photograph/document state.
3. Hash all acquired images: `sha256sum image.dd`.
4. Log every person who handles evidence.
5. Store on write-once media or WORM storage.
6. Maintain custody transfer forms.

### CERT-In reporting (2022 directions)

- Report cyber incidents within **6 hours** for: data breaches, ransomware, DDoS on critical infra, etc.
- Log retention: 180 days minimum.
- NTP synchronization required.

### Countermeasures

- Pre-draft incident response plan (IRP).
- Tabletop exercises quarterly.
- Retainer with legal counsel.
- Preserve logs centrally (SIEM) before attacker deletion.

---

*Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.*

## L36: Course Synthesis — Tool Chain Integration & Assessment

### Purpose

Integrate all tools into an end-to-end assessment workflow — capstone for nou26\_ge86.

### Capstone scenario

Assess a small e-commerce lab environment: 1. **Recon:** Nmap network scan. 2. **Enum:** Gobuster + Nikto on web server. 3. **Vuln scan:** OpenVAS full scan. 4. **Web test:** ZAP active scan + sqlmap on injection point. 5. **Wireless:** Document WPA configuration (if applicable). 6. **Defense:** Write Snort rule for attack traffic observed. 7. **Firewall:** iptables rules to block attacker IP. 8. **Credentials:** Demonstrate Hydra risk; recommend MFA. 9. **Report:** CVSS-rated findings + remediation + legal disclaimer.

### Report template

1. Executive summary
2. Scope and authorization
3. Methodology (tools + versions)
4. Findings table (ID, severity, CVSS, evidence, recommendation)
5. Conclusion and re-test plan

### Assessment prep

- Review all 36 lecture tool summaries.
- Watch BAOU YouTube channel: scsbaou5615.
- Complete PGDCS-103 Block review questions.
- Practice in isolated VMs only.

---

*Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.*